

SIEM Alert Pattern Detection and Response Playbook

Category: Procedures

Model: SIEM-RECOVERY-001

Description: This document details detection signatures and response procedures for SIEM beaconing alerts and anomaly patterns that surged during the August 12, 2025 incident. It covers specific alert signatures like BEACON-12xx, methods to confirm surge conditions, and initial containment steps to mitigate threats.

Table of Contents

1. [Introduction](#)
2. [Detection Signatures](#)
3. [Confirming Alert Surges](#)
4. [Initial Response Procedures](#)
5. [Detection Signature Examples](#)
6. [Containment Steps](#)
7. [API Throttling Playbook](#)
8. [Partner OAuth Review Procedures](#)
9. [Appendices](#)

1. Introduction

This playbook provides comprehensive detection and response guidance for cybersecurity incident management involving SIEM alert surges, particularly focusing on beaconing signatures and anomalous network activity observed during the incident on August 12, 2025. It is designed for security analysts,

incident responders, and threat hunters to standardize detection, validation, containment, and mitigation strategies.

The document leverages insights from threat-hunting activities over the past six months, integrating detection signatures, specific IOC indicators, network block lists, and contextual threat intel to facilitate rapid and effective response.

2. Detection Signatures

This section enumerates the key detection signatures utilized to identify malicious beaconing activity and other anomalous patterns associated with the incident and ongoing threat landscape.

2.1 Beaconing Signatures

Signature ID	Description	Detection Method	Examples
BEACON-12xx	Periodic outbound connections characteristic of beaconing activity, matching patterns like BEACON-1201, BEACON-1250.	SIEM pattern matching on outbound connection intervals, payload frequency, and destination domains.	Connections to domains like beacon-01.abc.com every 5 minutes.
C2-DNS-30xx	DNS queries to command-and-control domains exhibiting suspicious frequency or encoded patterns.	DNS query analysis for high-volume, encoded, or suspicious domain names.	Queries to domains like secret-c2-xyz.com with patterns like "adS456==".

2.2 Endpoint Detection & Response (EDR) Artifacts

- Observation of malicious process chains such as **mshta.exe** executing encoded PowerShell commands.
- SHA256 hashes associated with known malicious payloads:

File Name	SHA256 Hash
malicious_payload.exe	3f79e74719abf1234567890abcdef1234567890a
ransomware_variant.dll	7d3b7beca0f1234567890abcdef1234567890ab

2.3 IAM Audit Signatures

- Events indicating auto-creation of service accounts with suspicious scope IDs such as **SCOPE-PROD-API-ADMIN**.
- Unexpected increases in privileged service account activity during surge periods.
- Notable audit log entries:
 - Event ID: 5632 - Service account auto-creation event with scope ID: *SCOPE-PROD-API-ADMIN*
 - Event ID: 5760 - IAM policy or permission alterations on production resources.

2.4 Network Indicators (Block Lists)

- Malicious domains such as *c2-host-01.example* and associated IP ranges.

- ASN identifiers like **ASN-64512** observing abnormal outbound communication patterns.
- Sample Block List Entries:

Type	Identifier	Description
Domain	c2-host-01.example	Known command-and-control host identified during incident analysis.
IP Range	192.0.2.0/24	Suspicious IP subnet associated with malicious activity.
ASN	ASN-64512	ASN linked to malicious traffic surges.

2.5 Checkout Failure Codes

Common error codes indicating potential attack or system misconfiguration issues during surge events included:

Code	Meaning	Impact
PAY-408	Checkout timeout or request timeout during payment processing.	Possible sign of DoS or network congestion.
GATEWAY-52	Gateway communication failure.	Potential network intrusion or misconfigured firewall.
CART-ERR-1203	Error during cart validation process.	Possible fraudulent activity or internal error.

3. Confirming Alert Surges

To accurately confirm a surge in beaconing or anomalous activity, follow

these procedural steps:

1. **Data Aggregation:** Collect logs from SIEM, EDR, network appliances, and IAM alerts for a predefined window of *30 minutes*.
2. **Pattern Matching:** Analyze outbound connections and DNS queries against known signatures such as BEACON-12xx and C2-DNS-30xx.
3. **Volume Assessment:** Quantify the number of alerts/signatures exceeding baseline thresholds (e.g., >50 detections within 10 minutes).
4. **Contextual Correlation:** Correlate alerts with escalated IAM activities or network anomalies such as increases in ASN activity.
5. **Visual Inspection:** Use SIEM dashboards for timeline analysis and anomaly heat maps to identify coordinated surge activities.
6. **Verification:** Confirm alerts with endpoint telemetry showing malicious process chains (e.g., mshta.exe executing encoded commands) or known SHA256 hashes.

Example scenario: During August 12, 2025, a surge of over 200 BEACON-12xx signature hits was recorded in under 10 minutes, coinciding with increased ASN-64512 traffic and creation of suspicious IAM service accounts.

4. Initial Response Procedures

4.1 Immediate Actions

- **Isolate Affected Hosts:** Segregate compromised endpoints from the network, using VLANs or network ACLs.
- **Disable Malicious Accounts:** Suspend or disable IAM service accounts identified during the surge, especially ones with scope IDs like *SCOPE-PROD-API-ADMIN*.
- **Block Malicious Domains/IPs:** Implement network block rules for identified C2 domains and IP ranges such as *c2-host-01.example* or ASN-64512.
- **Activate Incident Response Team:** Notify the designated incident response team per organizational policies.

4.2 Containment Steps

Network Segmentation

Isolate impacted network segments to prevent lateral movement.

Log Collection

Ensure centralized log collection from endpoints, network devices, and SIEM for forensic analysis.

Threat Hunt

Initiate threat-hunting queries for IOC correlates such as hashes, signatures, and domains across the network.

All containment measures should be documented with timestamps, actions performed, and personnel involved.

5. Detection Signature Use Cases and Examples

5.1 Example 1: Beaconsing Pattern Detection

```
# SIEM Query snippet (pseudo):  
  
SELECT timestamp, source_ip, destination_domain, connection_interval  
FROM network_logs  
WHERE  
    destination_domain LIKE '%.abc.com' AND  
    connection_interval BETWEEN 240 AND 360 # seconds  
ORDER BY timestamp DESC  
LIMIT 100;
```

Interpretation: This query identifies outbound connections every 4-6 minutes to specific domains consistent with BEACON-12xx activity.

5.2 Example 2: DNS Anomaly Detection

```
# Alert for high-frequency DNS queries to suspicious domains
if dns_query_count(domain='secret-c2-xyz.com') > 10 per minute:
    trigger_alert('C2-DNS-30xx suspected activity')
```

5.3 Example 3: EDR Artifact Alert

Detection of mshta.exe executing with encoded PowerShell commands matching patterns like "*encodedcommand*" parameter, accompanied by suspicious SHA256 hashes.

6. Containment Steps

Effective containment involves a combination of technical controls and procedural measures:

1. **Disable suspicious accounts:** Immediately suspend or revoke permissions for auto-created or anomalous service accounts, e.g., those with scope IDs like *SCOPE-PROD-API-ADMIN*.
2. **Block malicious traffic:** Apply firewall rules to prevent outbound C2 traffic to known malicious domains/IPs listed in the block list.
3. **Isolate compromised systems:** Disconnect affected servers/endpoints from the network to halt further data exfiltration.
4. **Preserve evidence:** Collect volatile data (RAM dumps, process lists) and logs for forensic analysis.

Example command to add network block rules (pseudo):

```
iptables -A OUTPUT -d c2-host-01.example -j DROP
```

Note: Follow organizational procedures for network device configuration.

7. API Throttling Playbook

In instances where API abuse or high-volume requests contribute to surge incidents, implement throttling mechanisms:

- Apply rate-limiting rules on APIs exposed to external and internal clients.
- Monitor request rates via API gateways, setting thresholds such as 100 requests per minute per origin.
- Configure automated alerts when thresholds are exceeded, triggering further investigation.

Sample API Throttling Procedure:

1. Identify the API endpoints most affected during the surge.
2. Configure throttling policies in the API gateway (e.g., limit requests per IP).
3. Implement temporary block policies for IPs generating abnormal request volumes.
4. Audit logs continuously for unusual activity post-implementation.

8. Partner OAuth Review Procedures

During incident management, review and verify partner OAuth integrations to prevent abuse:

1. **Audit OAuth tokens:** Validate active tokens for unusual scope or creation patterns aligned with IAM anomalies.
2. **Restrict third-party access:** Temporarily revoke external OAuth applications exhibiting suspicious activity.
3. **Engage with partners:** Communicate findings and request updated security review of OAuth integrations especially for API-initiated access tied to service accounts.
4. **Implement least privilege:** Ensure OAuth token scopes are minimal, such as read-only permissions during surge mitigation period.

Record all reviews, actions, and communications for compliance and audit purposes.

9. Appendices

9. [redacted] [redacted] [redacted]
[redacted] [redacted]